Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Team members list

Team ID : SWTID-2026-5246

Team members : 5

Sno	Name	College	E-mail
1	Sathish K	Shri Nehru Maha vidyalaya College of Arts and Science	bscit311@gmail.com
2	Dheena dhayalan J	Shri Nehru Maha vidyalaya College of Arts and Science	deenadhayalanj468@gmail.com
3	santhosh M	Shri Nehru Maha vidyalaya College of Arts and Science	santhomani8287@gmail.com
4	Vigneshwaran S	Shri Nehru Maha vidyalaya College of Arts and Science	devilvicky0046@gmail .com
5	Logesh K	Shri Nehru Maha vidyalaya College of Arts and Science	ll3523643@gmail.com

Projectdetails

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, this project initiates a fundamental shift in our security architecture. We will be decommissioning our legacy VPN infrastructure, which relies on an outdated castle-and-moat model that grants excessive network access and is vulnerable to lateral threat movement. To replace it, we are adopting a cloud-native, Zero Trust approach powered by Zscaler. This new architecture is built on the principle of "never trust, always verify," ensuring that users are connected to applications, not to the network. By making applications invisible to the internet and establishing direct, secure user-to-app connections, we will drastically reduce our attack surface. This modern solution eliminates the risk of lateral movement, as threats can no longer traverse a flat network. Furthermore, it provides a superior, high-performance experience for our hybrid workforce, decoupling security from data center backhauling. The transition to Zscaler will not only bolster our security posture but also enhance agility and reduce the operational overhead associated with managing legacy hardware. This initiative is a critical step in future-proofing our organization against sophisticated cyber threats.

Abstract:
This project details the strategic migration from a legacy Virtual Private Network (VPN) infrastructure to a cloud-native Zero Trust Network Access (ZTNA) solution provided by Zscaler. The primary driver for this initiative is the fundamental inadequacy of traditional VPNs in the modern threat landscape. Legacy architectures operate on a "connect first, verify later" model, granting users broad access to the corporate network and, consequently, creating a significant risk of lateral movement by malicious actors. This expansive attack surface, combined with the operational overhead of managing physical appliances and the poor user experience associated with hair-pinned traffic, renders the existing model both insecure and inefficient for today's hybrid workforce.

The proposed solution leverages the Zscaler Zero Trust Exchange, a global, cloud-native platform that shifts connectivity from a network-centric to an identity and application-centric model. By making corporate applications invisible to the internet and establishing direct, secure connections between verified users and specific applications, the new architecture eliminates the concept of network-based privileges. This approach ensures that users connect to the applications they need, not the underlying network, thereby completely neutralizing the threat of lateral movement. Furthermore, it improves performance by steering traffic directly to Zscaler's edge nodes, optimizing the user experience regardless of their location.

The expected outcomes of this modernization project are multifaceted. We anticipate a drastic reduction in the organization's attack surface and the complete elimination of lateral movement risks. This will be coupled with a simplified, scalable security posture managed from a unified cloud console, reducing operational costs and complexity. Ultimately, this transition will not only fortify our cyber defenses against sophisticated threats but also enable a secure, high-performance, and agile work environment, future-proofing the organization's security architecture.

Use Case Scenarios:

Scenario 1: Third-Party Vendor Access to Finance Application

Scenario 2: Research Assistant Access to High-Performance Computing Cluster

Scenario 3: Administrative Staff Access to Internal File Server

Scenario 4: IT Administrator Secure Access to Server Management Interfaces

Scenario 5: Visiting Professor Access to Library Resources

Stage-1

Title Of the Project: -

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview: -

This project is a strategic initiative to fundamentally transform the organization's remote access and network security architecture by decommissioning the existing legacy Virtual Private Network (VPN) infrastructure and replacing it with a cloud-native Zero Trust solution from Zscaler. The current VPN model, based on a perimeter-centric "castle-and-moat" approach, inherently trusts users once they are connected, granting them broad access to the internal network. This expansive access creates a significant attack surface and leaves the organization vulnerable to lateral movement, where a single compromised credential can lead to a widespread breach. The operational challenges of managing, scaling, and patching legacy VPN appliances, coupled with the poor user experience of backhauled traffic, further underscore the urgent need for modernization. This project directly addresses these critical security and operational deficiencies.
The core of the new architecture is Zscaler Private Access (ZPA), which operates on a Zero Trust principle of "never trust, always verify" and "connect the user to applications, not the network." By making internal applications completely invisible to the internet and the public DNS, ZPA eliminates the attack surface associated with exposed ports and IP addresses. When a user requests access, ZPA verifies their identity and context—through integrations with identity providers like Azure AD and device posture checks—before establishing a secure, encrypted micro-tunnel. Crucially, this tunnel connects the user only to the specific application they are authorized to use, not to the underlying network. This effectively renders the network invisible to the end-user and eliminates any possibility of lateral movement, as threat actors cannot scan, discover, or pivot to other internal resources.
The anticipated outcomes of this modernization are profound and multi-faceted. The organization will achieve a drastically reduced attack surface and a complete eradication of lateral movement risks, significantly strengthening its security posture against advanced cyber threats.
Operationally, the shift to a cloud-native, globally distributed edge removes the need for traffic hair-pinning, thereby optimizing performance and user experience for a hybrid workforce. This transition also simplifies IT operations by replacing complex, hardware-dependent VPN infrastructure with a unified, scalable, and agile cloud management console. Ultimately, this project will not only fortify the organization's defenses but also create a secure, high-performance, and future-ready access framework that supports evolving business needs.

This expansive access creates a significant attack surface and leaves the organization vulnerable to lateral movement, where a single compromised credential can lead to a widespread breach. The operational challenges of managing, scaling, and patching legacy VPN appliances, coupled with the poor user experience of backhauled traffic, further underscore the urgent need for modernization. This project directly addresses these critical security and operational deficiencies. The core of the new architecture is Zscaler Private Access (ZPA), which operates on a Zero Trust principle of "never trust, always verify" and "connect the user to applications, not the network." By making internal applications completely invisible to the internet and the public DNS, ZPA eliminates the attack surface associated with exposed ports and IP addresses. When a user requests access, ZPA verifies their identity and context—through integrations with identity providers like Azure AD and device posture checks—before establishing a secure, encrypted micro-tunnel. Crucially, this tunnel connects the user only to the specific application they are authorized to use, not to the underlying network. This effectively renders the network invisible to the end-user and eliminates any possibility of lateral movement, as threat actors cannot scan, discover, or pivot to other internal resources.

List of Vulnerability Table:

Practice Website:

S.no	Vulnerability Name	CWE - No
1	Improper Sanitization of File Paths	CWE- 284: Improper Access Control
2	Invalid Certificate	CWE-395: Improper Certificate Validation
3	Missing X-Frame-Options Header	CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames
4	X-Content-Type Options Header Missing	CWE -918: Server-Side Request Forgery (SSRF)
5	Drupal Ajax API shows JSONP not disabled by default	CWE-937,1035: OWASP Top Ten 2013,2017 Category A9 - Using Components with Known Vulnerabilities

6	Drupal Api Vulnerability	CWE-20: Improper Input Validation
7	Improper API Filtration	CWE-79: Improper Neutralisation of Input During Web Page Generation ('Cross-site Scripting')
8	Denial of Service	CWE -400: Uncontrolled Resource Consumption
9	TLS Version 1.0 Protocol Detection	CWE-327: Use of a Broken or Risky Cryptographic Algorithm
10	web.config File Information Disclosure	CWE-497: Exposure of Sensitive System Information to an Unauthorised Control Sphere

Main Website:

S.no	Vulnerability Name	CWE - No
1	SL Medium Strength Cipher Suites Supported (SWEET32)	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor
2	Cookie SERVERID created without secure flag	CWE-79: Improper Neutralisation of Input During Web Page Generation
3	X-Content-Type Options Header Missing	CWE-918: Server-Side Request Forgery (SSRF)
4	Denial of Service	CWE -400: Uncontrolled Resource Consumption
5	OS Identification	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

REPORT: -

Practice Website: http://www.itsecgames.com/

1) Vulnerability Name: Improper Sanitization of File Paths

CWE- 284: Improper Access Control

OWASP Category: A01:2021-Broken Access Control

Description: The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor.

Business Impact: This vulnerability is significant, as it can lead to unauthorized access to sensitive data or files, potentially causing data breaches, privacy violations, and loss of user trust. Affected sites may also require configuration changes after applying a security release.

Steps to Reproduce: https://www.shodan.io/host/31.3.96.40

CVE-2023-31250	The file download facility doesn't sufficiently sanitize file paths in certain situations. This may result in users gaining access to private files that they should not have access to. Some sites may require configuration changes following this security release. Review the release notes for your Drupal version if you have issues accessing private files after updating.

Recommendation:

1. **Apply Security Updates** The primary recommendation is to apply the security update providedbyDrupalas soon as it becomes available. Security updates typically include fixes for known vulnerabilities like this one.

2. **Review Configuration**: After applying the update, review your Drupal site's configuration to ensure that private files remain protected as intended. Make any necessary adjustments to your site's file permissions or access controls.

3. **Regular Audits**: Conduct regular security audits and vulnerability assessments to identify and address potential security issues in your Drupal site.
4. **Access Control**: Implement strong access controls to ensure that only authorized users can access private files. Review and restrict file access permissions as needed.
5. **Data Minimization**: Minimize the amount of sensitive data stored on your Drupal site. Only store data that is necessary for your site's functionality.

2) Vulnerability Name: Invalid Certificate

CWE-395: Improper Certificate Validation

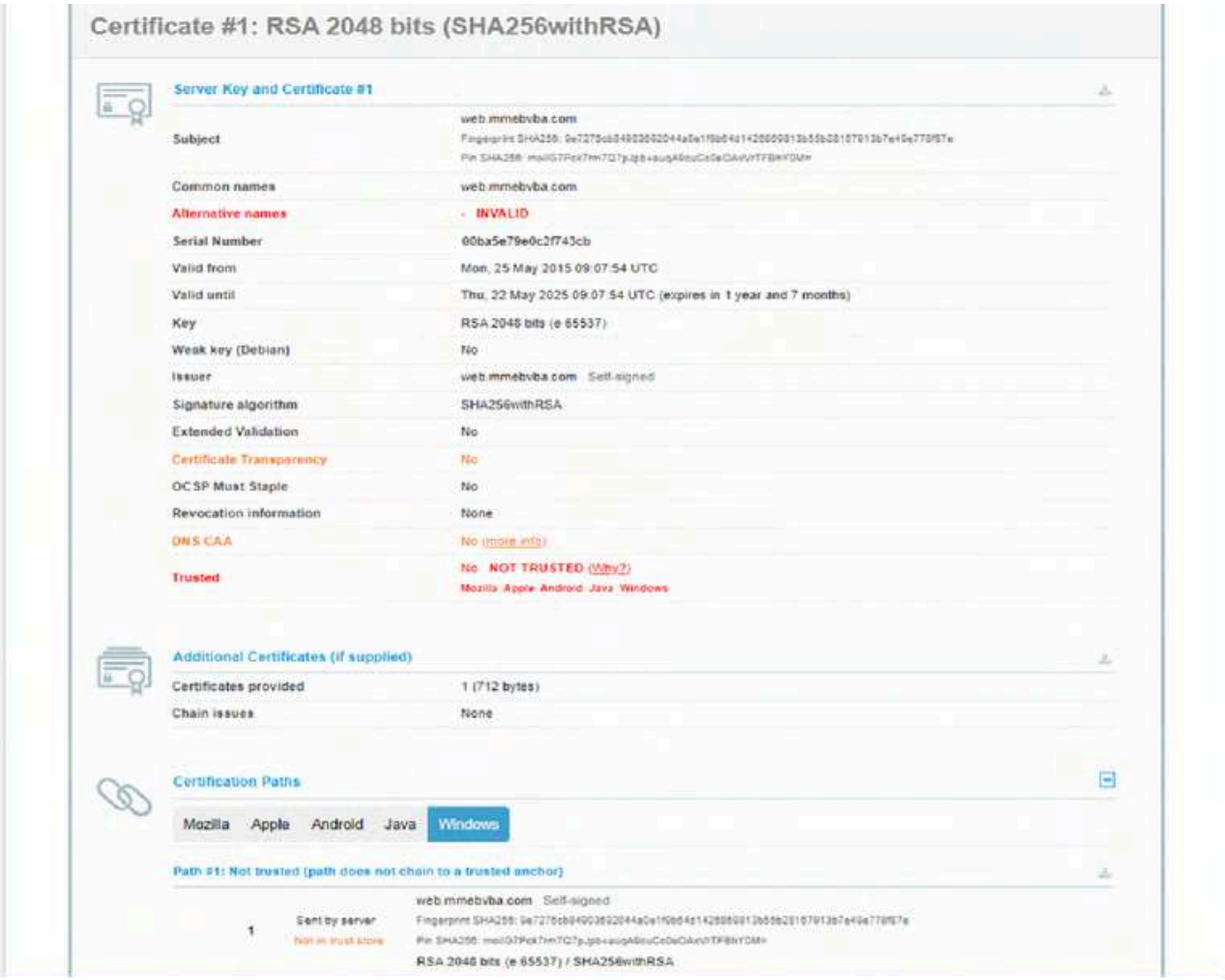
OWASP Category: A07:2021 – Identification and Authentication Failures

Description: When a certificate is invalid or malicious, it might allow an attacker to spoof a trusted entity by interfering in the communication path between the host and client. The product might connect to a malicious host while believing it is a trusted host, or the product might be deceived into accepting spoofed data that appears to originate from a trusted host.

Business Impact: Improper certificate validation can lead to a range of security threats which includes Man-in-the-middle attacks(Attackers can intercept communication between two parties and read or modify the data exchanged between them),Data breaches:(Attackers can gain unauthorized access to sensitive information or sensitive systems, leading to data breaches),Malware distribution(Attackers can use fake digital certificates to distribute malicious software or infect systems with malware)

Steps to Reproduce: https://www.ssllabs.com/ssltest/analyze?d=www.itsecgames.com

---



Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	web.mmebvba.com Fingerprint SHA256: 9e7275cb04903692044a0e1f9b64d142669913b55b2815791 3b7e49e770f87e Pin SHA256: mxIG7Pck7mn7Q7pJpb+augA6cuCc0eOAvVTFBhYOM=
Common names	web.mmebvba.com
Alternative names	- INVALID
Serial Number	00ba5e79e0c2f743cb
Valid from	Mon, 25 May 2015 09:07:54 UTC
Valid until	Thu, 22 May 2025 09:07:54 UTC (expires in 1 year and 7 months)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	web.mmebvba.com Self-signed
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	No
OCSP Must Staple	No
Revocation information	None
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

Certificates provided	1 (712 bytes)
Chain issues	None

Certification Paths

Mozilla Apple Android Java Windows

Path #1: Not trusted (path does not chain to a trusted anchor)

1	Sent by server Not in trust store	web.mmebvba.com Self-signed Fingerprint SHA256: 9e7275cb04903692044a0e1f9b64d142669913b55b2815791 3b7e49e770f87e Pin SHA256: mxIG7Pck7mn7Q7pJpb+augA6cuCc0eOAvVTFBhYOM= RSA 2048 bits (e 65537) / SHA256withRSA

Recommendation: 1. **Use trusted certificate authorities:**

trusted certificate authorities. Only trust digital certificates issued by well-known and

2. **Verify certificate chains:** Verify that the certificate presented by the remote party is valid and issued by a trusted certificate authority. Verify the entire certificate chain, including intermediate certificates.

3. **Check certificate revocation status:** Check the revocation status of the certificate presented by the remote party to ensure that it has not been revoked.

4. **Use certificate pinning:** Implement certificate pinning to ensure that the communication only occurs with the exact certificate or certificate authority specified.

5. **Keep software up to date:** Keep software and security protocols up to date, as new vulnerabilities and security patches are regularly released.

3) Vulnerability Name: Missing X-Frame-Options Header

CWE-1021: DesignImproperRestriction of RenderedUILayers or Frames

OWASP Category: A04:2021-Insecure Design

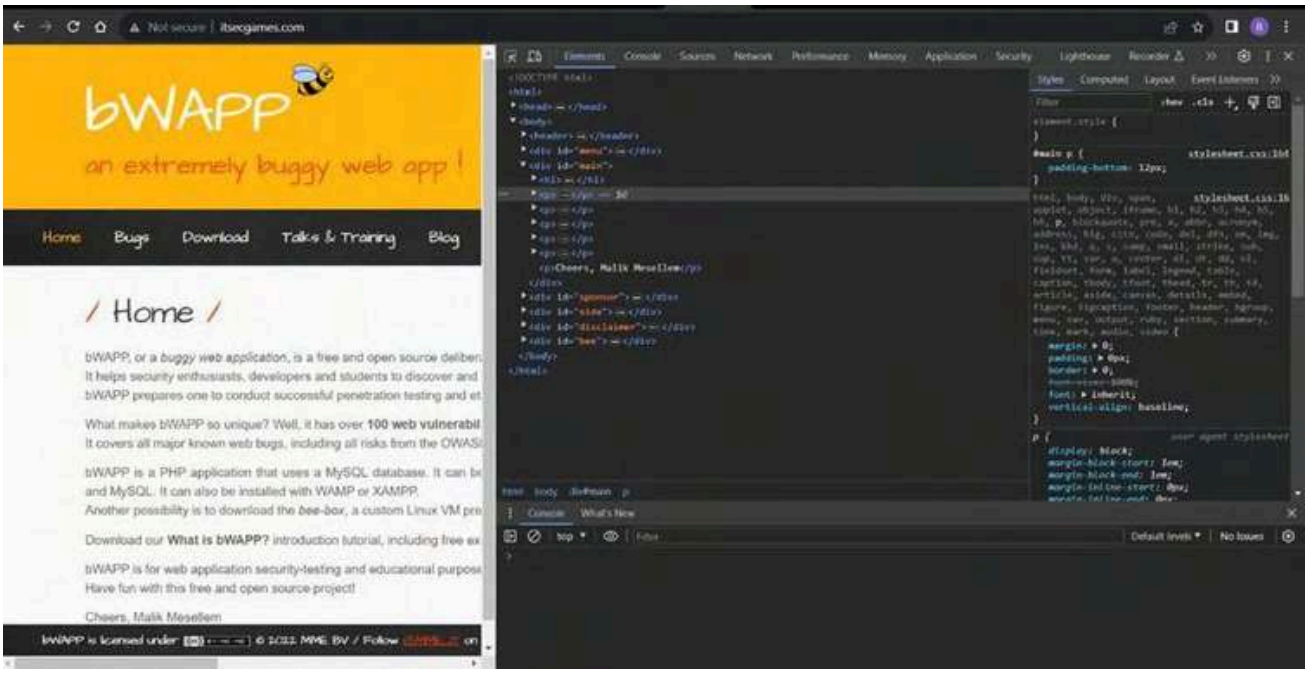
Description: A web application is expected to place restrictions on whether it is allowed to be rendered within frames, iframes, objects, embed or applet elements. Without the restrictions, users can be tricked into interacting with the application when they were not intending to.

Business Impact: This enables path to the attackers to manipulate or gain unauthorized access to user interface elements, potentially leading to deceptive or malicious user interactions. This can result in data leakage, fraud, user distrust, and reputational damage, undermining the integrity and trustworthiness of the application and causing financial losses.

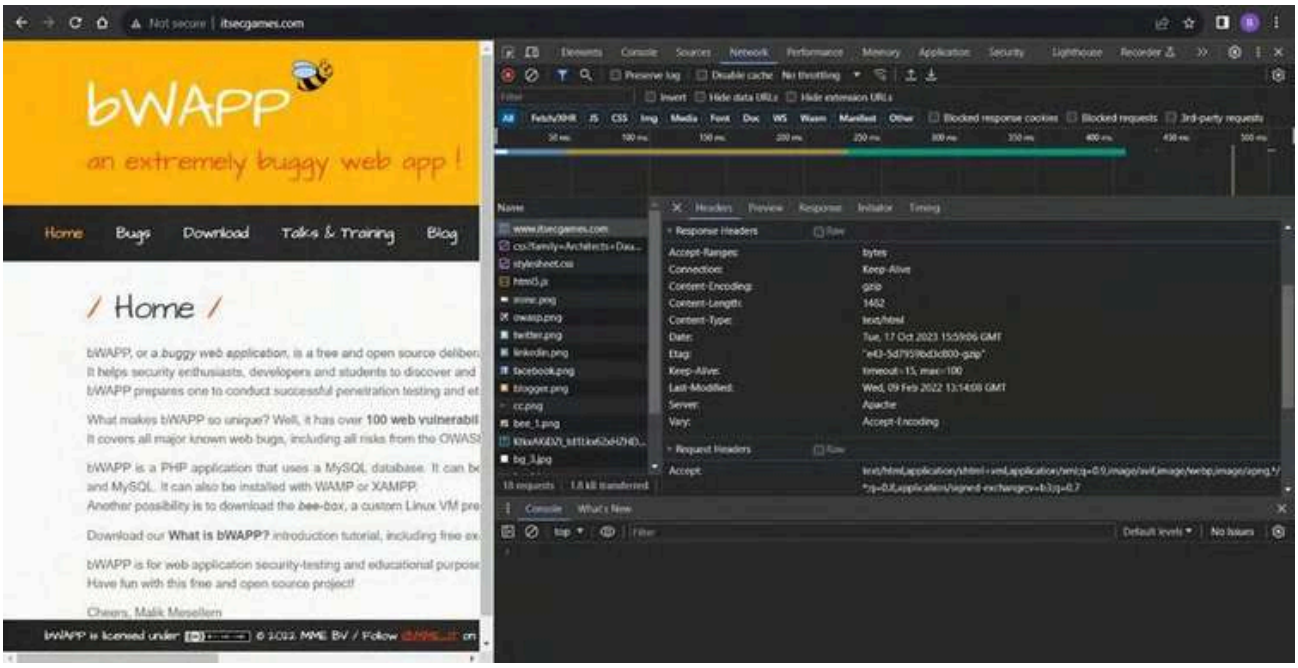
Vulnerability Path: http://www.itsecgames.com/

Steps to Reproduce:

1.Open the practice website to inspect



2. Go to network and start capturing using F5 or Ctrl+R 3. Go to html document and see if x-frame-options present in response headers or not 4. If not the absence of this header indicates that the website may not have protection against
embedding its content within an iframe on other domains, potentially leaving it vulnerable to clickjacking attacks.



Recommendation:

1. **Implement Proper UI Layer Access Controls:**Enforce access controls to restrict access to UI layers or frames based on user privileges.
2. **Use Session and Authentication Management:** Ensure robust session management and user authentication mechanisms to prevent unauthorized access.

3. **Implement Content Security Policies (CSP):** Use CSP headers to control where resources can be loaded from and mitigate against frame-based attacks.

4.**KeepSoftwareandLibraries Updated:** Stay current with software updates and patches to address known security issues.

4) Vulnerability Name: X-Content-Type Options Header Missing

CWE -918: Server-Side Request Forgery (SSRF)

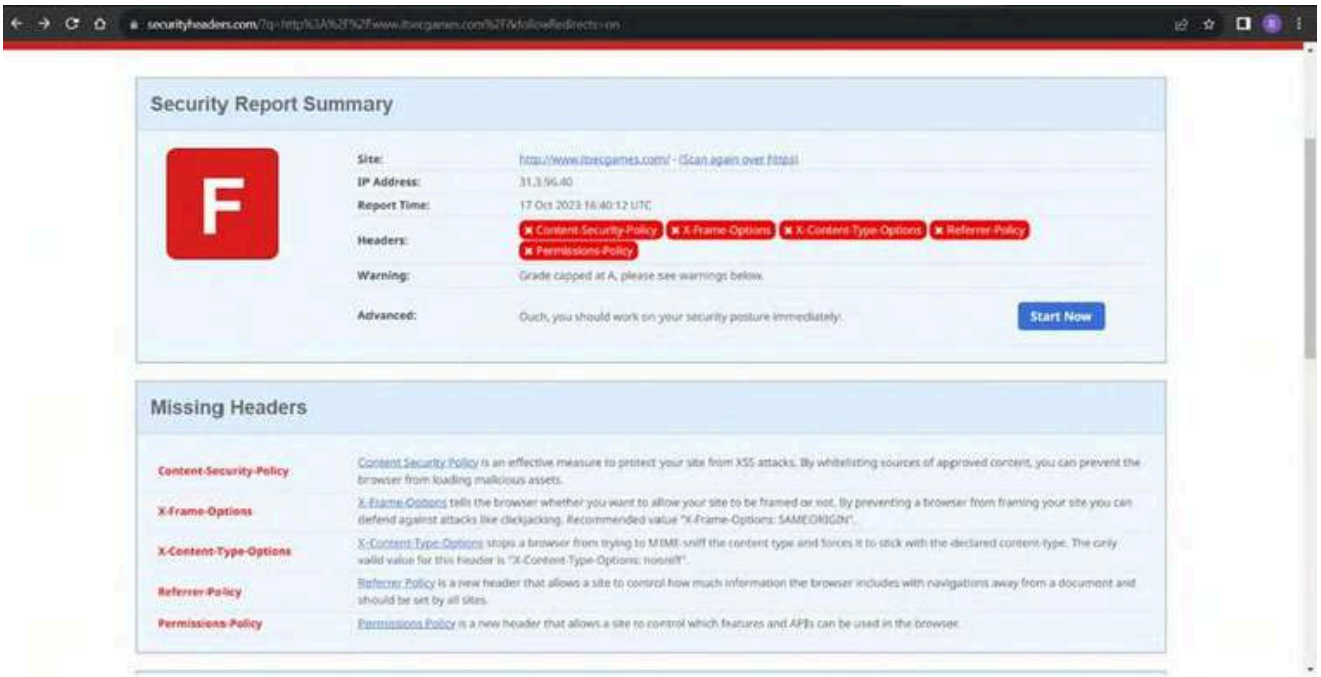
OWASP Category: A10:2021–Server-Side RequestForgery(SSRF)

Description: The webserver receives a URL or similarrequestfrom an upstream component and retrievesthe contentsof this URL, butit does notsufficientlyensure that the request is being sent to the expected destination.

Business Impact: The header missing impact Data Exposure(Attackers might force the server to render sensitive data as HTML, leading to data exposure),Security Risks(Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage(Successful attacks that exploit SSRF vulnerabilities can harm the organization's reputation and trustworthiness)

Vulnerability Path :
https://securityheaders.com/?q=http%3A%2F%2Fwww.itsecgames.com%2F&followRedirects=on

Steps to Reproduce:




```
┌──(thanmaye08㉿THANMAYE)-[~]
└─$ nikto -h http://www.itsecgames.com/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          31.3.96.40
+ Target Hostname:    www.itsecgames.com
+ Target Port:        80
+ Start Time:         2023-10-17 09:03:40 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.
org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the
content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-
vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /com.tgz: Drupal 7 was identified via the x-generator header. See: https://www.drupal.org/proje
ct/remove_http_headers
+ /com.tgz: Drupal Link header found with value: <http://31.3.96.40/>; rel="canonical",<http://31
.3.96.40/>; rel="shortlink". See: https://www.drupal.org/
+ /: Server may leak inodes via ETags, header found with file /, inode: e43, size: 5d7959bd3c800,
 mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-acce
ss-to-iconsreadme/
+ 8075 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time:           2023-10-17 09:29:14 (GMT5.5) (1534 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

- Implement "X-Content-Type-Options" Header: Configure the "X-Content-Type-Options" header with the value "nosniff" in your web server or application to prevent content type sniffing.

- Secure SSRF: To directly mitigate SSRF vulnerabilities, ensure proper input validation, access controls, and allow-list-based URL validation to prevent attackers from making unauthorized requests to internal resources.
- Security Headers: Implement other security headers like "X-Frame-Options" and "Content-Security-Policy" to further enhance security and mitigate various types of web-based attacks.

While the "X-Content-Type-Options" header may not be a direct countermeasure to SSRF, it is a valuable security control that, when configured correctly, can help protect against content type-based attacks that may be exploited in SSRF scenarios.

5) Vulnerability Name: Drupal Ajax API shows JSONP not disabled by default

CWE-937,1035: OWASP Top Ten 2013,2017 Category A9 - Using Components with Known Vulnerabilities

OWASP Category: A06:2021-Vulnerable and Outdated Components **Description:** Vulnerable

and outdated components refer to using software libraries, modules, or dependencies within a web application that have known security issues or are not updated to the latest secure versions. This can include plugins, frameworks, or APIs that are no longer maintained or have publicly documented vulnerabilities.

Business Impact: The presence of vulnerable and outdated components in a web application poses significant security risks. Attackers can exploit these weaknesses to gain unauthorized access, inject malicious code, steal sensitive data, or disrupt the system's operation. The potential business impacts include compromised user data, damaged reputation, legal consequences, and financial losses due to breach recovery and remediation efforts.

VulnerabilityPath: https://www.shodan.io/host/31.3.96.40

Steps to Reproduce:

CVE-2020-13666	4.3 Cross-site scripting vulnerability in Drupal Core. Drupal AJAX API does not disable JSONP by default, allowing for an XSS attack. This issue affects: Drupal Drupal Core 7.x versions prior to 7.73; 8.8.x versions prior to 8.8.10; 8.9.x versions prior to 8.9.6; 9.0.x versions prior to 9.0.6.

Recommendation:

1. **Regular Updates:** Keep all components, libraries, and dependencies up to date by applying security patches and upgrades.

2. **VulnerabilityScanning:** Conduct periodic vulnerability assessments to identify and address potential issues.
3. **Dependency Management:** Implement a strategy for managing third-party dependencies, including continuous monitoring of their security status.

4. **Security Testing:** Perform regular security testing, including penetration testing and code review, to identify and remediate vulnerabilities.
5. **Change Control:** Maintain a change management process to assess the impact of new components and ensure they don't introduce new vulnerabilities.

6) Vulnerability Name: Drupal Api Vulnerability

CWE-20: Improper Input Validation

OWASP Category: A03:2021–Injection

Description: The productreceives input or data, but it does not validate or incorrectly validates thattheinputhas theproperties that are required to process the data safely and correctly.
Business Impact: The impact of a successful SQL injection attack can be devastating for businesses. It can result in unauthorized access to sensitive information, data theft, financial losses, damage to reputation, and legal consequences. Depending on the nature of the application and data involved, SQL injection can lead to compliance violations, customer trust erosion, and operational disruption.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Steps to Reproduce:

CVE-2022-25271	4.3 Drupal core's form API has a vulnerability where certain contributed or custom modules' forms may be vulnerable to improper input validation. This could allow an attacker to inject disallowed values or overwrite data. Affected forms are uncommon, but in certain cases an attacker could alter critical or sensitive data.

Recommendation:

1. **Input Validation:** Implement rigorous input validation on all user inputs and ensure that only safe, sanitized data is passed to the database.

2. **Parameterized Queries:** Use parameterized queries or prepared statements to separate SQL code from user input, preventing malicious injections.

3. **Escaping User Input:** If parameterized queries are not feasible, escape user input before incorporating it into SQL queries to neutralize special characters.

4. **Least Privilege Principle:** Limit the permissions and access rights of database accounts to the minimum required for specific tasks to minimize the potential damage of an attack.

5. **WebApplication Firewalls (WAF):** Employ WAFs to filter and block malicious SQL injection attempts.

6. **Regular Security Testing:** Conduct regular security assessments, including penetration testing, to identify and address vulnerabilities.

7) Vulnerability Name: Improper API Filtration

CWE-79: ImproperNeutralization ofInputDuringWeb Page Generation ('Cross-site Scripting')

OWASP Category: A07-2017: Cross-siteScripting(XSS)

Description: The product does not neutralize or incorrectly neutralizes user-controllable input beforeitisplaced in output that is usedasa web pagethat is served to other users.

Business Impact: If exploited, this vulnerability allows attackers to inject malicious scripts into web pages, which can be viewed by other users. The potential business impacts include data theft, unauthorized access, compromised user accounts, damaged reputation, and financial losses. Attackers can use XSS to steal sensitive information, such as user credentials, personal data, or financial details, leading to regulatory compliance violations and legal liabilities. Additionally, defacement or manipulation of website content can erode customer trust and result in lost revenue.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Steps to Reproduce:

CVE-2020-13672	2.6 Cross-site Scripting (XSS) vulnerability in Drupal core's sanitization API fails to properly filter cross-site scripting under certain circumstances. This issue affects: Drupal Core 9.1.x versions prior to 9.1.7; 9.0.x versions prior to 9.0.12; 8.9.x versions prior to 8.9.14; 7.x versions prior to 7.80.

Recommendation:

1. **Update and Patch:**Ensure that Drupal and all related modules and components are up to date withthelatestsecuritypatches to mitigate known vulnerabilities.

2. **Input Validation:** Implement strong input validation and output encoding to sanitize user inputs and prevent the injection of malicious scripts.
3. **Content Security Policy (CSP):** Implement CSP headers to restrict the sources from which content can be loaded, reducing the risk of XSS.
4. **Secure Coding Practices:** Train developers in secure coding practices, emphasizing the importance of validating and escaping user inputs.
5. **Security Scanning:** Conduct regular security scans and penetration tests to identify and address XSS vulnerabilities.

8) Vulnerability Name: Denial of Service

CWE -400: UncontrolledResourceConsumption

OWASP Category:

Description: The Denial ofService (DoS) attack is focused on making a resource (site, application, server) unavailablefor the purpose it was designed. There are many ways to make a service unavailable for legitimate users by manipulating network packets, programming, logical, or resources handling vulnerabilities, among others. If a service receives a very large number of requests, it may cease to be available to legitimate users. In the same way, a service may stop if a programming vulnerability is exploited, or the way the service handles resources it uses.

Sometimes the attacker can inject and execute arbitrary code while performing a DoS attack in order to access critical information or execute commands on the server. Denial-of-service attacks significantly degrade the service quality experienced by legitimate users. These attacks introduce large response delays, excessive losses, and service interruptions, resulting in direct impact on availability.

Business Impact: If successfully exploited, it involves overwhelming a system or application with excessive demands on its resources. This can lead to a range of disruptive consequences. The targeted system may experience significant slowdowns, or even complete unresponsiveness, making it difficult or impossible for legitimate users to access. Critical resources like CPU, memory, and network bandwidth can become depleted, causing further degradation in performance. In severe cases, the exploited vulnerability may lead to system crashes or failures, potentially resulting in data loss. This disruption not only impacts business productivity and financial stability but also risks reputational damage, eroding customer trust and confidence. Additionally, organizations may face regulatory compliance issues if the uncontrolled resource consumption leads to violations of service level agreements or industry standards. Mitigating this vulnerability requires proactive resource management practices and a well-prepared incident response plan to minimize the potential impacts on business operations and customer satisfaction.

Steps to Reproduce: exploit open ports 80 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ sudo su
[sudo] password for paavan:
┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap --top-ports 65536 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
zsh: segmentation fault  sudo nmap --top-ports 65536 31.3.96.40

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap -sV -p 80 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
Nmap scan report for web.mmebvba.com (31.3.96.40)
Host is up (0.043s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.28 seconds

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# msfconsole
```

```
Metasploit tip: Open an interactive Ruby terminal with
irb
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 31.3.96.40
RHOST => 31.3.96.40
msf6 auxiliary(dos/tcp/synflood) > set RPORT 80
RPORT => 80
msf6 auxiliary(dos/tcp/synflood) > RUN
[-] Unknown command: RUN
msf6 auxiliary(dos/tcp/synflood) > run
[*] Running module against 31.3.96.40

[*] SYN flooding 31.3.96.40:80 ...
```

Recommendation: Employ a robust Web Application Firewall (WAF) capable of filtering and mitigating suspicious traffic targeting port 80. Configure it to block excessive requests or patterns indicative of an attack. Utilise load balancing techniques to distribute traffic across multiple servers, ensuring no single server becomes overwhelmed. Additionally, implement rate limiting and throttling mechanisms to restrict the number of requests a single IP address can make within a defined time frame. Regularly monitor traffic patterns and set up alerts to detect unusual spikes in activity, enabling rapid response to potential attacks. Finally, keep software and systems up-to-date with the latest security patches to address known vulnerabilities that attackers may exploit.

9) Vulnerability Name: TLS Version 1.0 Protocol Detection

CWE-327: UseofaBrokenorRiskyCryptographicAlgorithm

OWASP Category: A02:2021-Cryptographic Failures

Description: Theproduct uses a broken or riskycryptographicalgorithm or protocol.

Business Impact: TLS 1.0 is an outdated and vulnerable encryption protocol, and its use can expose sensitivedata to potential security threats. This not only jeopardizes the integrity of customer information and payment details but also tarnishes the company's reputation. The business may face legal consequences, loss of customer trust, and decreased revenue as security-conscious users avoid the site due to its security vulnerabilities. Immediate action is necessary to upgrade to a more secure TLS version to safeguard data, ensure compliance, and maintain customer confidence.

Steps to Reproduce:

1. Open a terminal or command prompt

2. Type the Command: openssl s_client -connect 31.3.96.40:443 -tls1

3. The connection is successfully means the server supports TLS 1.0

thanmaye08@THANMAYE: ~

File Actions Edit View Help

```
┌──(thanmaye08㉿THANMAYE)-[~]
└─$ openssl s_client -connect 31.3.96.40:443 -tls1
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 CN = web.mmebvba.com
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN = web.mmebvba.com
verify return:1
---
Certificate chain
 0 s:CN = web.mmebvba.com
   i:CN = web.mmebvba.com
   a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
   v:NotBefore: May 25 09:07:54 2015 GMT; NotAfter: May 22 09:07:54 2025 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIICxDCCAaygAwIBAgIJALpeeeDC90PLMA0GCSqGSIb3DQEBCwUAMBoxGDAWBgNV
BAMMD3dlYi5tbWVidmJhLmNvbTAeFw0xNTA1MjUwOTA3NTRaFw0yNTA1MjIwOTA3
NTRaMBoxGDAWBgNVBAMMD3dlYi5tbWVidmJhLmNvbTCCASIwDQYJKoZIhvcNAQEB
BQADggEPADCCAQoCggEBAK/hFlEmVRyv2fbXel6oUukbiGdpX0Xps5sqis2OxF9Y
/YXJcxaPoI/fUyfSdJ6prr2/YoEcUUfZaUIJWbsSz/qzklja0M+GMAVzL+wqAi+V
HjgujqsgeEQgxgTiNoQu9Zld5NY7Ac9qQRKbLBLRubQV/9+Dud0Isx3z1gAsJda6
bi3JuL0a27EMztRssKeQClJhWLAdidjuXH6kc+3jbNPmvedRF+Mw5mk32nNtyZ78
qjIFT7Bny/CNGN31PFgQWq+6pTgCzokui04zV0pYyaGX9hs6roLiQWLT9UqB0wx0
Jr+GM175u2YLvXba+UZ2cWMOp5IZ359OHtkf0uuKSzUCAwEAAaMNMAswCQYDVR0T
BAIwADANBgkqhkiG9w0BAQsFAAOCAQEAgKAHg1qFsUlDarYKIrjuUxfeI2bE1fLd
VGIYBzmaQddzehzBu9Akn9g73DHwrs9+gW9cDfkClVr3ayzS5KAMhvnZzga1B0+q
NYfX2y61SMnS4w9p8PT3iqZdF/RYwu658BXjpJWojwoA8Hu1mhwT0DdSSEofBnIq
azNm62lQsxdTlU7wEanZ0/ExUFNktwKean7Jle3EvH94fkNg2T0er1WuEB/QF6sv
dJqxsYSZ3toPEuqlOryWis0E8pfo3Hauzz6fBGijLcEnMoFp7oCZNz0Xh9Q93aOs
5c9hNmHtQcu3vMrYUYArpj+a/euAEI2HaGJZf5g75mf4gAI/2B7iyg==
-----END CERTIFICATE-----
subject=CN = web.mmebvba.com
issuer=CN = web.mmebvba.com
---
No client certificate CA names sent
Peer signing digest: MD5-SHA1
Peer signature type: RSA
Server Temp Key: ECDH, prime256v1, 256 bits
---
SSL handshake has read 1404 bytes and written 274 bytes
Verification error: self-signed certificate
---
New, TLSv1.0, Cipher is ECDHE-RSA-AES256-SHA
Server public key is 2048 bit
Secure Renegotiation IS supported
Compression: NONE
Expansion: NONE
```

```
No ALPN negotiated
SSL-Session:
    Protocol  : TLSv1
    Cipher    : ECDHE-RSA-AES256-SHA
    Session-ID: 88C081DC5A60B2165E5ECF1174DFFA77732428624861E0BFAC934E3DE969B9E2
    Session-ID-ctx:
    Master-Key: 9A895BD34544E92181A631AB636C46EEC2788E9BFEE0DA5A6BDCA50E65C55250BA88EA
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 300 (seconds)
    TLS session ticket:
    0000 - 11 e0 e2 5c 44 79 52 91-7b 32 b1 10 22 9f 80 b5    ...\DyR.{2..".....
    0010 - 54 b6 b7 89 fe c7 7d 4a-18 bd 8c e3 e6 31 47 63    T.....}J.....1Gc
    0020 - 38 1b 52 ec 16 ac 18 b6-bd e1 76 e9 4b 41 24 ad    8.R.......v.KA$.
    0030 - e3 94 d2 60 65 35 8b e0-6e d2 76 db 1b e1 03 e7    ...`e5..n.v.....
    0040 - e7 76 cc f9 70 6a 42 91-94 42 e2 e8 29 d5 fd 38    .v..pjB..B..)..8
    0050 - 63 5f da 9f 09 af e0 d9-22 29 45 70 a7 a4 36 1f    c_......")Ep..6.
    0060 - 51 b1 cd d5 e7 b9 ef 9d-5d 20 99 ad 00 4d 21 df    Q.......] ...M!.
    0070 - 38 a6 c9 1b 76 29 87 d9-14 79 7a 73 33 f8 4c 8f    8...v)...yzs3.L.
    0080 - 12 ae 66 c1 ad c3 6c ba-68 63 11 6c b2 18 e0 89    ..f...l.hc.l....
    0090 - 97 54 50 d7 ee f5 e1 37-f4 b0 be 55 2f d1 25 63    .TP....7...U/.%c
    00a0 - c7 61 10 b3 ad 74 5a b7-07 fe e5 20 b1 da a1 a2    .a...tZ.... ....
    00b0 - be dd c8 45 a7 74 b7 eb-ee 9a 15 dc 1b bb 0b d9    ...E.t..........

    Start Time: 1697691531
    Timeout   : 7200 (sec)
    Verify return code: 18 (self-signed certificate)
    Extended master secret: no
---
4037A3514B7F0000:error:0A000126:SSL routines:ssl3_read_n:unexpected eof while reading:
```

Recommendation:

1. **Upgrade to a Secure TLS Version:**Transition to a more secure TLS version, such as TLS 1.2 orTLS1.3.Thiswillprovidestrongerencryption and improved security against modern threats.

2. **Regularly Update SSL/TLS Configuration:** Keep your SSL/TLS configuration up to date to ensure it aligns with the latest security best practices and vulnerabilities.

3. **Implement a Strong Cryptographic Suite:** Use strong cipher suites and secure configurations to further enhance security. Disable weak ciphers and outdated protocols.

4. **Compliance Checks:** Ensure that your website complies with relevant data protection regulations and industry standards (e.g., GDPR, PCI DSS) to avoid legal issues.

10) Vulnerability Name: **web.config File Information Disclosure**

CWE-497: ExposureofSensitiveSystemInformationtoanUnauthorized Control Sphere

OWASP Category: A3:2017-Sensitive Data Exposure

Description: An information disclosure vulnerability exists in the remote web server due to the disclosure of the web.config file. An unauthenticated, remote attacker can exploit this, via a simple GET request, to disclose potentially sensitive configuration information.

Business Impact: It exposes sensitive configuration details, including database connection strings and encryption keys, to potential attackers. This could lead to unauthorized access, data breaches, and system compromise. The impact includes financial losses, damage to reputation, and legal liabilities as the organization's security and customer trust are compromised.

Steps to Reproduce:

```
GET /web.config HTTP/1.1
Host: web.mmebvba.com
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*



This produced the following truncated output (limited to 5 lines) :
------------------------------ snip ------------------------------
<?xml version="1.0" encoding="UTF-8"?>
<configuration>
<system.webServer>
<!-- Don't show directory listings for URLs which map to a directory. -->
<directoryBrowse enabled="false" />
[...]
```

Recommendation:

- Implement proper access controls to restrict access to the web.config file.
- Prevent directory traversal and ensure the web.config file cannot be directly accessed through the web server.
- Encrypt sensitive data within the configuration file.
- Regularly review and update the web.config file, removing any unnecessary sensitive information.
- Ensure that the web.config file is properly secured and not accessible to unauthorized users.

Main Website: vtop.vit.ac.in

1) Vulnerability Name: SL Medium Strength Cipher Suites Supported (SWEET32)

CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

OWASP Category: Broken accesscontrol

Description: The remote host supports the use ofSSL ciphers that offer mediumstrength encryption. Nessus regards mediumstrength as anyencryption that uses keylengthsatleast 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Business Impact: The vulnerability known as SWEET32 (Short for Sweet 32 Birthday Attack) relates to the continued use of legacy cryptographic cipher suites with 64-bit block sizes in TLS and SSL protocols. These suites are susceptible to birthday attacks, which exploit the probability of two blocks colliding after a certain number of transactions. If an organisation's systems are vulnerable to SWEET32, it means they're potentially at risk of having encrypted communications intercepted or manipulated. This could lead to unauthorised access, data theft, or even the injection of malicious code. As a result, businesses face a significant risk to the confidentiality and integrity of their sensitive information. Remediation involves updating systems to support more secure cipher suites with larger block sizes, which would effectively mitigate this vulnerability and enhance the overall security posture. Failure to address SWEET32 could leave an organisation exposed to increasingly sophisticated attacks and legal consequences due to potential data breaches.

Vulnerability Path : The Sweet32 vulnerability when detected with a vulnerability scanner will report it as a CVSS 7.5.

Steps to Reproduce:

HIGH SSL Medium Strength Cipher Suites Supported (SWEET32)

Description

The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Solution

Reconfigure the affected application if possible to avoid use of medium strength ciphers.

See Also

https://www.openssl.org/blog/blog/2016/08/24/sweet32/
https://sweet32.info

Output

```
Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

  Name                      Code          KEX          Auth     Encryption            MAC
  ----------------------    ----------    ---          ----     ---------------------  ---
  EDH-RSA-DES-CBC3-SHA      0x00, 0x16    DH           RSA      3DES-CBC(168)         SHA1
  ECDHE-RSA-DES-CBC3-SHA    0xC0, 0x12    ECDH         RSA      3DES-CBC(168)         SHA1
  DES-CBC3-SHA              0x00, 0x0A    RSA          RSA      3DES-CBC(168)         SHA1

The fields above are :

  {Tenable ciphername}
  {Cipher ID code}
  Kex={key exchange}
  Auth={authentication}
  Encrypt={symmetric encryption method}
  MAC={message authentication code}
  {export flag}
```

To see debug logs, please visit individual host

Port ▸	Hosts
443 / tcp / www	136.233.9.22

Plugin Details

Severity:	High
ID:	42873
Version:	1.21
Type:	remote
Family:	General
Published:	November 23, 2009
Modified:	February 3, 2021

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: PoC
Age of Vuln: 730 days +
Product Coverage: High
CVSSV3 Impact Score: 3.6
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 6.1
Risk Factor: Medium
CVSS v3.0 Base Score 7.5
CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CVSS v2.0 Base Score: 5.0
CVSS v2.0 Vector:
CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N

Vulnerability Information

Vulnerability Pub Date: August 24, 2016

Recommendation: organisations should take several proactive steps. Firstly, it is crucial to update and configure cryptographic libraries, web servers, and any network devices to disable support for cipher suites with 64-bit block sizes. This can be achieved by ensuring that only modern and secure cipher suites are enabled in the TLS/SSL configurations. Additionally, organizations should regularly monitor and assess their systems for any outdated or vulnerable protocols and promptly apply security patches and updates. Implementing strong, unique encryption keys and employing forward secrecy protocols can further bolster security. It's also recommended to utilize intrusion detection systems and perform regular security audits to identify and address any potential vulnerabilities promptly. Lastly, organizations should stay informed about emerging security threats and best practices in cryptographic protocols to proactively adapt their security measures. By taking these measures, businesses can significantly reduce the risk of falling victim to SWEET32 attacks and enhance the overall security of their digital infrastructure.

2) Vulnerability Name: **Cookie SERVERID created without secue flag**

CWE-79: Improper Neutralization of Input During Web Page Generation

OWASP Category: A07-2017: Cross-site Scripting

Description: The vulnerability allows an attacker to inject malicious code into a WordPress website, which can then be executed by visitors to the website.

To exploit this vulnerability, an attacker would simply need to trick a user into clicking on a malicious link or opening a malicious attachment. Once the user clicks on the link or opens the attachment, the attacker's code would be executed, giving the attacker control over the user's account and potentially the entire WordPress website.

Business Impact: The business consequences of XSS can be severe, ranging from reputational damage due to compromised customer trust, to legal repercussions in cases of data breaches. Moreover, it can lead to financial losses through fraud or the cost of remediation efforts. Beyond the immediate impacts, long-term harm may occur if customers abandon the platform due to security concerns. To mitigate CWE-79, businesses must implement rigorous input validation and output encoding practices, as well as stay vigilant for emerging threats in web application security. Failure to address XSS vulnerabilities could result in significant harm to both the business's reputation and its bottom line.

Vulnerability Path: https://securityheaders.com/

q=http%3A%2F%2F~~vtop.vit.ac.in%2F&follow~~Redirects=on

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

1. **Update and Patch:** EnsurethatDrupal and all related modules and components are up to datewiththelatestsecuritypatchestomitigate known vulnerabilities.
2. **Input Validation:** Implementstrong input validation and output encoding to sanitize userinputsand preventtheinjectionofmalicious scripts.
3. **Content Security Policy (CSP):** Implement CSP headers to restrict the sources from whichcontent canbeloaded, reducingthe risk of XSS.
4. **Secure Coding Practices:** Traindevelopers in secure coding practices, emphasizing the importance of validatingand escapinguser inputs.
5. **Security Scanning:** Conductregular security scans and penetration tests to identify and addressXSS vulnerabilities.

3) **Vulnerability Name:** **X-Content-Type Options Header Missing**

CWE-918: Server-SideRequest Forgery (SSRF)

OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

Description: The absence of the "X-Content-Type-Options" header poses a notable security risk forweb applications. This header is a crucial security feature that instructs the browser to interpret files with a MIME type as declared in the Content-Type header, rather than trying to guess the type. When this header is missing, the browser may attempt to infer the content type, leaving room for potential misinterpretation and security vulnerabilities like MIME-sniffing attacks. This could enable attackers to disguise malicious content, such as scripts or executable files, as benign content, leading to Cross-Site Scripting (XSS) or other types of attacks. Implementing the "X-Content-Type-Options" header with the value "nosniff" is a fundamental security measure that helps prevent these risks. It ensures that browsers strictly adhere to the declared content type, enhancing the overall security posture of the web application and safeguarding against potential exploitation stemming from content misinterpretation.

Business Impact: The header missing impact Data Exposure(Attackers might force the server to render sensitive data as HTML, leading to data exposure),Security Risks(Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage(Successful attacks that exploit SSRF vulnerabilities can harm the organization's reputation and trustworthiness)

Vulnerability Path :
https://securityheaders.com/?q=http%3A%2F%2Fvtop.vit.ac.in%2F&followRedirects=on

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

- Implement "X-Content-Type-Options" Header: Configure the "X-Content-Type-Options" header with the value "nosniff" in your web server or application to prevent content type sniffing.
- Secure SSRF: To directly mitigate SSRF vulnerabilities, ensure proper input validation, access controls, and allow-list-based URL validation to prevent attackers from making unauthorized requests to internal resources.
- Security Headers: Implement other security headers like "X-Frame-Options" and "Content-Security-Policy" to further enhance security and mitigate various types of web-based attacks.

While the "X-Content-Type-Options" header may not be a direct countermeasure to SSRF, it is a valuable security control that, when configured correctly, can help protect against content type-based attacks that may be exploited in SSRF scenarios.

4) **Vulnerability Name:** **Denial of Service**

CWE - 400: Uncontrolled Resource Consumption

Description: The Denial of Service (DoS) attack is focused on making a resource (site, application, server) unavailablefor the purpose it was designed. There are many ways to make a service unavailable for legitimate users by manipulating network packets, programming, logical, or resources handling vulnerabilities, among others. If a service receives a very large number of requests, it may cease to be available to legitimate users. In the same way, a service may stop if a programming vulnerability is exploited, or the way the service handles resources it uses. Sometimes the attacker can inject and execute arbitrary code while performing a DoS attack in order to access critical information or execute commands on the server. Denial-of-service attacks significantly degrade the service quality experienced by legitimate users. These attacks introduce large response delays, excessive losses, and service interruptions, resulting in direct impact on availability.

Business Impact: If successfully exploited, it involves overwhelming a system or application with excessive demands on its resources. This can lead to a range of disruptive consequences. The targeted system may experience significant slowdowns, or even complete unresponsiveness, making it difficult or impossible for legitimate users to access. Critical resources like CPU, memory, and network bandwidth can become depleted, causing further degradation in performance. In severe cases, the exploited vulnerability may lead to system crashes or failures, potentially resulting in data loss. This disruption not only impacts business productivity and financial stability but also risks reputational damage, eroding customer trust and confidence. Additionally, organizations may face regulatory compliance issues if the uncontrolled resource consumption leads to violations of service level agreements or industry standards. Mitigating this vulnerability requires proactive resource management practices and a well-prepared incident response plan to minimize the potential impacts on business operations and customer satisfaction.

Steps to Reproduce: exploit open ports 443 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
┌──(root㉿kali)-[/home/paavan]
└─# nmap -O vtop.vit.ac.in
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-19 18:27 IST
Nmap scan report for vtop.vit.ac.in (136.233.9.22)
Host is up (0.044s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
465/tcp  closed smtps
3306/tcp closed mysql
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X|5.X (89%), Apple macOS 10.13.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5.1 c
Aggressive OS guesses: Linux 3.10 - 4.11 (89%), Linux 5.1 (87%), Apple macOS 10.13 (High Sierra
85%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.27 seconds
```

```
┌──(root㉿kali)-[/home/paavan]
└─# msfconsole

       =[ metasploit v6.3.27-dev                          ]
+ -- --=[ 2335 exploits - 1220 auxiliary - 413 post       ]
+ -- --=[ 1385 payloads - 46 encoders - 11 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit tip: Adapter names can be used for IP params
set LHOST eth0
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 136.233.9.22
RHOST => 136.233.9.22
msf6 auxiliary(dos/tcp/synflood) > set RPORT 443
RPORT => 443
msf6 auxiliary(dos/tcp/synflood) > exploit
[*] Running module against 136.233.9.22

[*] SYN flooding 136.233.9.22:443...
^C[-] Stopping running against current target...
[*] Control-C again to force quit all targets.
[*] Auxiliary module execution completed
msf6 auxiliary(dos/tcp/synflood) >
```

Recommendation: employ a robust Web Application Firewall (WAF) capable of filtering and mitigating suspicious traffic targeting port 80. Configure it to block excessive requests or patterns indicative of an attack. Utilise load balancing techniques to distribute traffic across multiple servers, ensuring no single server becomes overwhelmed. Additionally, implement rate limiting and throttling mechanisms to restrict the number of requests a single IP address can make within a defined time frame. Regularly monitor traffic patterns and set up alerts to detect unusual spikes in activity, enabling rapid response to potential attacks. Finally, keep software and systems up-to-date with the latest security patches to address known vulnerabilities that attackers may exploit.

5) **Vulnerability Name:** **OS Identification**

CWE-200: ExposureofSensitiveInformation to an Unauthorised Actor

OWASP Category: A02:2021-Cryptographic Failures

Description: Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.),itis possible to guessthe name oftheremote operating system in use. It is also possible sometimes to guess the version of the operating system.

Business Impact: If sensitive information is improperly handled or inadequately protected, it can lead to financial losses, regulatory penalties, and damage to reputation. Customers may lose trust in the organization's ability to safeguard their data, potentially resulting in a loss of business and market share. Legal consequences and compliance issues may arise, leading to additional costs. Moreover, intellectual property theft or exposure can compromise a company's competitive edge. Remediation efforts, including implementing stronger security measures and compensating affected parties, can also entail substantial expenses. Overall, CWE-200 highlights the critical importance of robust data protection measures to safeguard an organization's financial health, reputation, and long-term viability.

Steps to Reproduce: use nmap -O TARGET to enable os detection

```
┌──(root㉿kali)-[/home/paavan]
└─# nmap -O vtop.vit.ac.in
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-19 19:13 IST
Nmap scan report for vtop.vit.ac.in (136.233.9.22)
Host is up (0.043s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
465/tcp  closed smtps
3306/tcp closed mysql
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X|5.X (89%), Apple macOS 10.13.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:apple:mac_os_x:10.13 cpe:/o:linux:linux_kernel:5.1
Aggressive OS guesses: Linux 3.10 - 4.11 (89%), Apple macOS 10.13 (High Sierra) (Darwin 17.0.0) (86%), Linux 5.1 (86%), Linux 3.2 - 4.9 (86%), Linux 3.18 (
85%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.42 seconds
```

Recommendation: implementing robust encryption protocols for data both in transit and at rest, coupled with stringent access controls and strong authentication measures. Regular vulnerability assessments and penetration testing should be conducted to identify and rectify potential weak points. Educating employees through comprehensive security awareness training is vital, emphasising proper data handling practices and recognition of potential threats. Employing data masking techniques for non-production environments and utilising advanced Data Loss Prevention (DLP) solutions can further fortify defences. Additionally, maintaining compliance with relevant data protection laws and regulations, as well as establishing a well-defined incident response plan, are crucial components of a comprehensive strategy to safeguard against sensitive information exposure.

This is stage 1 in the context of web application testing and security
we take help from

OWASP top 10 to understand them. The OWASP Top 10 is a widely recognized list of the most critical web application security risks. Understanding these risks is essential for ensuring the security of web applications.

Stage 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
- Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.
- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- http://testfire.net/
Target ip address:- 65.61.137.117

List of vulnerability:-

s.no	Vulnerability name	Severity	plugins
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446
7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615
9	HSTS Missing From HTTPS Server	INFO	84502
10	HTTP Server Type and Version	INFO	10107

REPORT: -

1) Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection

Severity: - MEDIUM

Plugin: - 104743

Port: - 443

Description: - Theremoteserviceacceptsconnectionsencrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact: -Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Non-compliance risks regulatory penalties and erodes customer trust. Moreover, endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence.

2) Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated

Severity: MEDIUM

Plugin:- 157288

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1

As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Business Impact: -The continued use of TLS 1.1 with its lack of support for modern cipher suites and advanced encryption methods jeopardizes the organization's security posture, increasing vulnerability to cyber threats and potential data breaches. Additionally, endpoints not upgraded to support TLS 1.2 and higher will encounter compatibility issues with major web browsers and vendors, impacting user experience and potentially leading to missed business opportunities. Swift remediation of this vulnerability is essential to mitigate security risks and ensure seamless interactions with web browsers and vendors, preserving the organization's reputation and operational efficiency.

3) Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Severity: - LOW

Plugin: - 83875

Port: - 443

Description: - The remote hostallows SSL/TLS connections withoneor more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact: - Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust.

4) Vulnerability Name: - 10114 - ICMP Timestamp Request Remote Date Disclosure

Severity: - INFO

Plugin: - 10114

Port: - 0

Description: - Theremote hostanswersto anICMP timestamp request. Thisallowsanattacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution: - Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Business Impact: -This does not pose an immediate threat to business operations or data security. This vulnerability allows external parties to request the system's date and time information remotely. While it does not present a significant risk, it could potentially be used by attackers for reconnaissance purposes. Therefore, it is advisable to address this vulnerability as part of a broader security posture to reduce the risk of unauthorized data gathering and protect against potential future threats.

5) Vulnerability Name: - 46180 - Additional DNS Hostnames

Severity: - INFO

Plugin: - 46180

Port: - 0

Description: - Hostnamesdifferent fromthe current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as : www.example.com [192.0.32.10]

Business Impact: -This does not pose an immediate threat to business operations or data security. It indicates the discovery of hostnames that are associated with the remote host, particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk on its own, it could be useful for understanding the server's configuration and infrastructure. Organizations should consider this information as part of their network documentation but do not need to take immediate action to mitigate it as a security threat.

6) Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: -INFO

Plugin:- 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution:- n/a

BusinessImpact:- Is an informational finding that identifies the presence of a remote Apache Tomcat web server. While this information itself does not indicate a security threat or impact on business operations, it can be useful for network administrators and security professionals to be aware of the technologies in use on their network. Understanding the presence of an Apache Tomcat server can be valuable for maintaining and securing web applications, but it does not require immediate action to mitigate a security risk.

7) Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)

Severity: - INFO

Plugin: - 45590

Port: - 0

Description: - By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Solution: - n/a

Business Impact: - This provides insights into hardware and software products identified on a host through a Nessus scan. It reports CPE matches, which are standardized identifiers for these products. This information is valuable for asset management and inventory purposes. While it doesn't signify a security threat, it aids administrators in understanding the components within their network, contributing to effective resource management and facilitating future system maintenance.

8) Vulnerability Name: - Device Type

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based onthe remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution: -

Business Impact: - This aids in the identification of the remote system type, such as a printer, router, or general-purpose computer, based on the remote operating system. While this doesn't pose a direct security threat, it offers valuable insights for network administrators to better understand and classify the devices in their network. This information aids in network

management, optimization, and ensures that the right security measures are in place for each device type.

9) Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server

Severity: -INFO

Plugin:- 84502

Port: - 443

Description: -The remote HTTPS server is not enforcing HTTP Strict Transport Security (HSTS). HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: - Configure the remote web server to use HSTS**.**

Business Impact: -Indicates that the remote HTTPS server does not enforce HTTP Strict Transport Security (HSTS). HSTS is a crucial security feature that, when configured on the server, instructs web browsers to communicate exclusively via HTTPS, enhancing security. The absence of HSTS potentially exposes the server to downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens protections against cookie hijacking, posing risks to data confidentiality and user security. Enabling HSTS is essential to ensure a higher level of protection for data transmitted between clients and the server.

10) Vulnerability Name: - 10107 - HTTP Server Type and Version

Severity: - INFO

Plugin: - 10107

Port: - 443

Description: - This plugin attempts to determine the type and the version of the remote web server.

Solution: - N/A

Business Impact: -

This relates to the identification of the remote web server's type and version. While this issue doesn't pose an immediate security threat, it can provide valuable information to potential attackers about the server's software stack. Knowledge of the server type and version may aid attackers in exploiting known vulnerabilities specific to that software, making it important to restrict such information from being easily accessible to enhance the server's overall security posture.

Stage-3

Title: - Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

• Legacy VPN Architecture

Legacy VPNarchitecture is a network security model that creates an encrypted tunnel between a remote user and an organization's internal network using on-premises hardware appliances like VPN concentrators . Unlike modern solutions, legacy VPNs operate on an "authenticate once, trust indefinitely" principle. Once a user successfully authenticates, they are placed directly onto the internal network with an IP address, effectively becoming a node on that network . This architecture was designed for a different era when all users were in offices and all applications were in data centers. It relies on the concept of a "trusted internal network" versus an "untrusted external internet"—the castle- and-moat model . The VPN concentrator acts as the drawbridge: once crossed, the user is trusted and granted broad access to internal resources based on their IP address rather than their identity . **• Limitations of Legacy VPN** Legacy VPN architectures present significant security and operational challenges in today's distributed work environment. The limitations include:

1. Over-permissioned Access: Once connected, users gain network-level access, meaning a compromised faculty laptop can scan, discover, and attack other systems on the internal network (lateral movement) .
2. Expanded Attack Surface: VPN concentrators must be exposed to the public internet with open ports (typically IPsec on UDP 500 or SSL VPN on TCP 443), making them visible targets for port scanning, brute-force attacks, and vulnerability exploitation .
3. Poor User Experience: Traffic is often "hair-pinned"—routed from the user to the data center and then out to the internet for SaaS applications—causing latency and slow performance .
4. Scalability Challenges: Hardware VPN appliances have hard capacity limits. During peak times (e.g., start of semester), users face connection failures, requiring manual upgrades of expensive hardware .
5. Operational Overhead: IT staff must patch, upgrade, and maintain physical VPN appliances, applying firmware updates and managing certificates .

• The Problem: Lateral Movement and Attack Surface

The core security weaknesses of legacy VPNs are the expanded attack surface and the risk of lateral movement.
Attack Surface: The VPN concentrator's publicly exposed IP address and open ports invite constant scanning and attacks. Threat actors use tools to identify VPN appliances and exploit known vulnerabilities (e.g., CVE-2019-11510, a critical Pulse Secure VPN vulnerability). Each exposed port is a potential entry point .
Lateral Movement: Once an attacker gains access via a compromised credential or vulnerability, they inherit the user's network-level access. The internal network, traditionally flat, allows the attacker to move laterally. From a single compromised faculty laptop, they can:

- Scan for other vulnerable servers (e.g., databases, file shares)
- Perform ARP spoofing or pass-the-hash attacks

- Pivot to high-value targets like the student information system or research data repositories
- Deploy ransomware across the network

• Zero Trust Architecture

Zero Trust Architecture (ZTA) is a security framework that eliminates the concept of trusted and untrusted networks. It operates on the principle of "never trust, always verify" and "least privilege access." Every access request is fully authenticated, authorized, and encrypted before granting access, regardless of whether the user is in the office or working remotely .

The core tenets of Zero Trust include:

1. Assume Breach: Design the network as if attackers are already present.
2. Verify Explicitly: Authenticate and authorize based on identity, device health, and context.
3. Least Privilege Access: Grant only the minimum access necessary to perform a job function.
4. Micro-segmentation: Isolate workloads and users from one another to prevent lateral movement.

• ZscalerZeroTrust Solution

Zscaler is a cloud-native security platform that delivers Zero Trust capabilities entirely from the cloud, eliminating the need for on-premises VPN hardware. The solution consists of two primary components relevant to this project:

1. Zscaler Private Access (ZPA): A ZTNA service that provides seamless, identity-based access to private applications without placing users on the network. It connects users to applications, not the network .
2. Zscaler Internet Access (ZIA): A secure web gateway that inspects all internet-bound traffic for threats and data loss, protecting users regardless of location .

Together, they create a comprehensive Zero Trust replacement for legacy VPN architectures.

• How Zscaler Eliminates Attack Surface

Zscaler eliminates the attack surface by making the organization's applications completely invisible to the public internet.

This is achieved through:

1. No Inbound Ports: Zscaler ZPA uses Zscaler App Connectors—lightweight VMs deployed in the data center—that initiate *outbound* connections to the Zscaler cloud. No inbound firewall ports need to be opened for remote access .
2. Application Invisibility: To an external port scanner, the university's applications do not exist. There are no IP addresses to scan, no ports to probe, and no VPN concentrators to attack .
3. DNS Resolution: ZPA does not rely on public DNS to resolve internal application names. Applications are never exposed to the public DNS infrastructure .
4. Dark Cloud Principle: The Zscaler cloud acts as a broker. Users connect to the cloud, and the cloud connects to the application. The application server never sees the user’s IP, and the user never sees the server’s IP—only the application itself .

• How Zscaler Prevents Lateral Movement

Zscalerpreventslateralmovement byensuring users are connected to applications, not to the network.

The mechanisms include:

1. Application Segmentation: ZPAestablishes a one-to-one, encrypted micro-tunnel between the user's device and the specific application they are authorized to access. The user never receives an IP address on the internal network .
2. No Network Visibility: Because the user is not placed on the network, they cannot scan, discover, or connect to other resources. There is no routing to adjacent systems. The network is invisible .
3. Identity-Based Micro-segmentation: Access policies are tied to user identity, not IP addresses. Even if an attacker compromises a user's credentials, they can only access the specific applications that user is authorized for—nothing else .
4. Continuous Monitoring: Zscaler monitors the connection throughout the session. If suspicious behavior is detected (e.g., impossible travel, anomalous data transfer), the connection can be terminated in real-time, preventing further movement .

•Zscaler Architecture Components

To understandhowZscaler replacesthe legacy VPN, it is essential to understand its core components:

1. Zscaler Client Connector: A lightweight software client installed on user devices (laptops, desktops, mobile devices). It intelligently forwards traffic:

- Private application traffic → ZPA for secure access
- Internet-bound traffic → ZIA for security inspection
- Bypassed traffic → Direct to internet (for performance)

2. Zscaler App Connector: A software component deployed as a VM in the university's data center or cloud environment. It initiates outbound connections to the Zscaler cloud and brokers connections to internal applications. Key features:

- No inbound firewall rules required
- Automatically scales horizontally based on load
- Can be deployed in multiple locations for high availability

3. Zscaler Cloud: The global security platform that enforces policies, brokers connections, and inspects traffic. It consists of over 150 data centers worldwide, ensuring low-latency access .

4. Zscaler Admin Portal: The centralized management console where administrators configure:

- Accesspolicies
- Application definitions
- User and group mappings
- Security settings
- Integration Points

Zscaler integrates with existing university infrastructure to leverage current investments:

1.IdentityProvider (IdP) Integration:

- Azure AD / Okta: Zscaler integrates with the university's existing IdP for user authentication and MFA. This ensures consistent identity management and allows users to use their existing credentials .
- SAML 2.0 / OpenID Connect: Supports modern authentication protocols for seamless single sign-on (SSO).

2. Endpoint Protection Integration:
- CrowdStrike / Microsoft Defender / Tanium: Zscaler checks device posture with integrated endpoint detection and response (EDR) tools. Access can be conditional on:
  - Antivirus running and up-to-date
  - Disk encryption enabled
  - OS patch level current
  - Device not jailbroken/rooted

3. SIEM/SOAR Integration:
- Splunk / Sentinel: Zscaler logs can be forwarded to the university's security information and event management (SIEM) system for centralized monitoring, alerting, and threat hunting .

4. Threat Intelligence Integration:
- MISP Integration: Zscaler can consume threat intelligence feeds from MISP to block access to known malicious domains, IPs, and URLs via ZIA .

• MISP (Malware Information Sharing Platform) Integration

MISP is an open-source threat intelligence platform that enables sharing of indicators of compromise (IOCs) within the security community. Integrating MISP with Zscaler enhances threat detection capabilities.

1. Threat Intelligence Ingestion:
- MISP aggregates IOCs from multiple sources—industry ISACs, open-source feeds, and internal threat research .
- These IOCs include malicious domains, IP addresses, URLs, and file hashes associated with known malware campaigns, phishing attacks, and command-and-control (C2) servers .

2. Integration Mechanism:
- The security team configures MISP to push threat intelligence feeds to the Zscaler cloud via API .
- Zscaler normalizes this data into its threat intelligence database .

3. Proactive Blocking:
- When a faculty member—even one authorized via ZPA—attempts to access a website that matches an IOC from the MISP feed, ZIA blocks the request .

4. Enhanced Threat Correlation:
- Security analysts can use MISP to cross-reference Zscaler logs. For example, if anomalous outbound traffic is detected from a compromised device, analysts can query MISP to determine if the destination IP is associated with a known threat actor .

• Deployment Methodology

Deploying Zscaler to replace the legacy VPN requires a structured, phased approach:

Phase 1: Discovery and Planning (Weeks 1-2)

1. Application Discovery: Catalog all internal applications currently accessed via VPN. This includes:
   - Student Information System (SIS)
   - ERP (Finance/HR)
   - Library resources

- o Research computing clusters
- o Internal file servers
- o Administrative portals

2. User Segmentation: Define user groups and their application access requirements:
   - o Faculty: ERP, research servers, file shares
   - o Students: Library resources, learning management system
   - o Staff: Administrative portals, finance applications
   - o IT Admins: Server management interfaces
   - o External Collaborators: Specific research applications only
3. Traffic Analysis: Understand current traffic patterns to plan Zscaler Internet Access (ZIA) forwarding methods (PAC file, tunnel, or proxy).

Phase2: Infrastructure Deployment (Weeks3-4)

1. Deploy App Connectors:
   - o Provision App Connector VMs in the university data center (minimum 2 for high availability)
   - o Configure them with outbound internet access to connect to Zscaler cloud
   - o No inbound firewall rules required
2. Configure App Connector Groups:
   - o Group connectors by function or location
   - o Associate them with specific applications for traffic steering

3. Integrate Identity Provider:
   - o Configure SAML 2.0 between Zscaler and Azure AD
   - o Map user groups from Azure AD to Zscaler
   - o Test authentication flow

Phase 3: Policy Configuration (Weeks 5-6)

1. Define Applications in ZPA:
   - o Add each internal application (by IP, port, and protocol)
   - o Associate applications with App Connector groups
   - o Configure application segmentation

2. Create Access Policies:
   - o Build granular policies based on user groups:
     - *"Facultycan accessERP onTCP443 fromdevices with antivirus enabled afterMFA"*
     - *"Researchers canaccess HPCCluster onTCP22 from managed devices only"*
     - *"External Collaborators can access Research Repository on TCP 443 between9 AM-5 PM"*
3. Configure ZIA Policies:
   - o Set up URL filtering
   - o Enable threat protection (IPS/IDS)
   - o Configure data loss prevention (DLP) rules for sensitive data

Phase 4: Pilot Deployment (Weeks 7-8)

1. Select Pilot Group:Chooseasmall group of willing faculty and IT staff (10-20 users).
2. Deploy Zscaler Client Connector: Provide installation instructions and assist with setup.
3. Monitor and Validate:
    - Verify authentication and MFA flows
    - Test application access
    - Validate that users cannot access unauthorized applications
    - Collect feedback on performance
4. Refine Policies: Adjust based on pilot feedback and any access issues.

Phase 5: Full Deployment and Migration (Weeks 9-12)

1. PhasedRollout: Deploy touser groups in waves:
    - Week 9: Faculty and researchers
    - Week 10: Administrative staff
    - Week 11: Students (if applicable)
    - Week 12: IT staff and remaining users
2. Communication and Training:
    - Send pre-deployment emails with instructions
    - Provide user guides for Zscaler Client Connector
    - Establish support channels for issues
3. Legacy VPN Decommissioning:
    - Once all users are migrated, revoke legacy VPN access
    - Shut down VPN concentrators
    - Remove public DNS records pointing to VPN

Phase 6: Optimization and Continuous Improvement (Ongoing)

1. LogAnalysis:Regularlyreview Zscalerlogs inthe admin portal for anomalies.
2. Policy Refinement: Update policies based on changing user roles and application additions.
3. Threat Hunting: Use integrated threat intelligence (MISP) to proactively search for compromised accounts.

•Threat Intelligence in Zscaler Environment

Threat intelligence transforms Zscaler from anaccess control tool into a proactive security platform. It provides context about who is trying to access what, from where, and with what risk.

Sources of Threat Intelligence:

1. Zscaler Cloud Logs: Real-time data on connections, including:
    - User identity and group membership
    - Source IP and geolocation
    - Destination application and IP
    - Bytes transferred and session duration
    - Device posture information
2. External Threat Feeds (MISP): Structured IOCs from trusted sources:

o Known malicious domains (e.g., phishing sites) o Command-and-control server IPs o Ransomware distribution URLs o File hashes of malware samples

3. Identity Provider Logs: Authentication data from Azure AD:
   o Successful and failed login attempts
   o MFA status
   o Impossible travel anomalies

4. EDR Integration: Endpoint detection tools provide:
   o Compromised device alerts
   o Malware detections
   o Anomalous process behavior

Applications of Threat Intelligence:

1. Adaptive Access Control:
   - If threat intelligence identifies a user's source IP as high-risk (e.g., known TOR exit node or malicious VPN), Zscaler can:
     - Step-up authentication (require additional MFA)
     - Block access entirely
     - Restrict to read-only access
     -
2. Compromised Account Hunting:
   - Analysts query Zscaler logs to identify:
     - Users accessing applications at unusual hours
     - Unusual data transfer volumes (potential exfiltration)
     - Access from unusual geographic locations
     -

   o Cross-reference with MISP to see if destination IPs are known malicious
3. Proactive Threat Blocking:
   o MISP feeds are pushed to ZIA for real-time enforcement
   o When any user attempts to access a blocked domain, the request is denied
   o Alerts are generated for security team investigation

• Incident Response in Zero Trust Model

Incident response is fundamentally improved in a Zscaler Zero Trust environment. The ability to instantly revoke access and the inherent lack of lateral movement transforms how security teams respond to threats.
Incident Response Workflow:

1. Detection:
   - Alert Trigger: The SOC receives an alert from Zscaler logs or integrated EDR tool. Example: A faculty account is downloading 50GB of research data at 3:00 AM, far exceeding normal behavior.
   - Investigation Initiation: The analyst opens the Zscaler admin portal and views the session details:
     o User: Dr. Smith (Faculty_Research group)
     o Device: Laptop "FAC-LT-342" (Windows 11, Defender active)
     o Application: Research Data Repository (SMB share)

- o Data transferred: 50GB in 15 minutes
- o Source IP: Unusual location (country different from user's normal location)

2. Containment:
   - Instant User Isolation: The analyst navigates to the user profile in the Zscaler portal and clicks "Deactivate User" or "Block Device." This action:
     - o Terminates all active Zscaler connections immediately
     - o Prevents any new authentication attempts
     - o Takes effect globally within seconds (no firewall rules to update)
   - Impact of Containment: Because the user was never on the network, there is no lateral movement to contain. The attacker is limited to the single compromised application and cannot pivot.
3. Eradication:
   - The compromised device is remotely wiped or taken offline by IT helpdesk.
   - The user's password is reset in Azure AD.
   - The analyst checks MISP and Zscaler logs to determine how the account was compromised (e.g., phishing email received earlier that day).
   - The malicious domain from the phishing email is added to Zscaler's block list (or automatically ingested via MISP).
4. Recovery:
   - Once the device is clean (re-imaged or malware removed) and the password is reset, the analyst re-enables the user in Zscaler.
   - The user authenticates with MFA from a clean device and regains access only to authorized applications.
   - All subsequent activity is closely monitored for 24-48 hours.
5. Post-Incident Review:
   - The security team analyzes the incident to identify root cause and process improvements.
   - Zscaler policies are updated: perhaps additional restrictions on sensitive research data (e.g., require approval for downloads over 1GB).

Benefitsof ZTNA-Based Incident Response:

1. Containment Speed: Actions take seconds in a cloud dashboard versus hours reconfiguring firewall ACLs or disabling VPN accounts .
2. No Lateral Movement: The blast radius is limited to the single compromised application; the rest of the university network remains protected .
3. Complete Audit Trail: Zscaler provides granular logs of every connection, session, and data transfer for forensic analysis .
4. Remote-First Design: Incident response can be conducted entirely from the cloud, without requiring physical access to data center equipment .
5. Compliance Demonstration: The detailed logs and access controls help demonstrate compliance with FERPA, HIPAA (if applicable), and other regulations .

Conclusion: -

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In **Stage 1**, understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

Stage 2 delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

Stage 3 The replacement of the legacy VPN architecture with a cloud-native Zscaler Zero Trust solution marks a pivotal transformation in the organization's security posture. By shifting from a network-centric to an application-centric model, this project successfully eliminates the expanded attack surface inherent in publicly exposed VPN concentrators and completely eradicates the risk of lateral movement. The implementation of Zscaler Private Access (ZPA) ensures that users are connected only to specific applications after rigorous identity and device verification, rendering the internal network invisible. This modernization not only fortifies defenses against sophisticated cyber threats but also delivers a superior, low-latency experience for the hybrid workforce, establishing a future-ready security foundation..

Considering the future scope, **Stage 1** illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

Stage 3 illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world.

In essence, the project not only provided a deep understanding of the current state zero trust using ZSCALER but also offered a glimpse into the exciting future of cybersecurity. Embracing these advancements will be crucial for organisations aiming to fortify their digital landscapes in the face of ever-evolving cyber threats.

Future Scope: -

Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable.

Here are some of the key trends that are expected to shape the future of WAT:

- Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.
- Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.
- Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

- Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.
- Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.
- Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future scope of SOC / SEIM:-

While the current project successfully replaces the legacy VPN with Zscaler ZPA for remote access, the Zero Trust journey offers several avenues for future expansion and enhancement:

1. **Workload-to-Workload Segmentation:** Extend Zero Trust principles beyond user-to-application connectivity to secure communication between internal workloads themselves. By deploying Zscaler Workload Segmentation, the university can enforce micro-segmentation within the data center and cloud environments, preventing lateral movement even between application tiers (e.g., web server to database server) without relying on network firewall rules.
2. **Branch and Campus Transformation:** Expand the Zscaler deployment to eliminate MPLS circuits and traditional hub-and-spoke networking. By routing all branch and campus internet traffic directly through Zscaler Internet Access (ZIA), the organization can reduce costs, improve performance, and apply consistent security policies to all users, regardless of their physical location.
3. **OT and IoT Security Integration:** Extend Zero Trust coverage to operational technology (OT) and Internet of Things (IoT) devices on campus, such as building management systems, security cameras, and lab equipment. Zscaler can provide visibility and segmentation for these often-unmanaged devices, ensuring they cannot be used as an entry point to attack core academic systems.
4. **Advanced Data Loss Prevention (DLP):** Enhance Zscaler deployment with advanced DLP capabilities to protect sensitive research data and student information. Future phases can include fingerprinting of sensitive documents, exact data matching (EDM) for structured data like student records, and integration with insider threat management tools to detect and block anomalous data exfiltration attempts.

5. **AI-Driven Threat Hunting:** Leverage Zscaler's AI-powered analytics and the integration with threat intelligence platforms like MISP to implement proactive threat hunting. Machine learning models can baseline normal user behavior and automatically flag anomalies—such as impossible travel or unusual data access patterns—for immediate investigation by the security operations center (SOC).
6. **Privileged Remote Access for Vendors:** Formalize and secure access for external vendors and contractors who require temporary access to specific systems for maintenance and support. Zscaler's privileged remote access capabilities can provide time-bound, session-recorded, and approval-based access to critical infrastructure without granting network-level privileges.
7. **Integration with SOAR Platforms:** Integrate Zscaler with security orchestration, automation, and response (SOAR) platforms to enable automated incident response workflows. For example, if Zscaler detects a compromised device, the SOAR platform can automatically trigger service desk tickets, isolate the device from the network, and reset the user's Active Directory credentials.
8. **Continuous Compliance Automation:** Utilize Zscaler logs and APIs to automate compliance reporting for regulations such as FERPA, GDPR, and HIPAA. Future development can include real-time compliance dashboards that demonstrate least-privilege access, data protection controls, and audit readiness to regulators and internal auditors.
9. **Zero Trust for Mergers and Acquisitions:** As the university grows or partners with other institutions, Zscaler can provide a secure framework for rapidly integrating new users and applications. Zero Trust principles ensure that acquired entities can access specific resources without being placed on the internal network, maintaining security during transitional periods.
10. **User Behavior Analytics (UBA):** Implement advanced user behavior analytics to detect insiderthreats and compromised accounts. By analyzing patterns of application access, data transfervolumes, and login times, machine learning algorithms can identify subtle indicators of malicious activity that rule-based policies might miss.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: -

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END